

Smart Contract Audit Report

Forton Master Contract Tact Multi-Contract System, TON

A review of the Forton membership system on TON: the deployed master contract, its message interface, the owner's control over pricing and routing, and the payment and duplicate-join behaviour seen in production. The audit was performed in September 2025 and published on 1 October 2025. This edition re-verifies every factual statement against the live chain on 22 September 2026, about a year after the original report, and corrects statements that the available evidence does not support.

OVERALL RISK RATING **MEDIUM**

PREPARED BY SOKEN LTD, Smart Contract Security	ORIGINAL REPORT September 2025 audit, published 1 October 2025 (v2)
THIS EDITION 22 September 2026, figures re-verified	NETWORK TON mainnet, workchain 0
MASTER CONTRACT EQAvJuEln0lP8c2YMZ4sKGwQRt_kmxmC494v8Y4TTHg0asKJ	OWNER EQA_LY9WjuDSFsjtNGqBb5M8QQzmaMf9P8-MTPkFCHQ9PoFq
FINDINGS 0 Critical, 0 High, 1 Medium, 0 Low, 5 Informational	REVIEW BASIS Deployed bytecode, ABI and live transactions; source not published

SOKEN LTD. Security review of on-chain code. Not financial, investment or legal advice. See the disclaimer in section 09.

01 Executive summary

Forton is a paid membership and group system on TON, built in Tact as several cooperating contracts. Users send a `Join` message with a fee to the master contract, which forwards it to a per-user contract and on to program contracts selected by an index. The master also accepts `GiftJoin` and `CreateSquad`, and owner messages that set the join and squad prices and the program addresses. The master was deployed on 24 April 2025 11:54 UTC and is in active use: it received 478 user joins from 476 distinct senders in the eight days to 22 September 2026.

Forton's source code is not published, so this is a review of deployed bytecode, the client-supplied ABI and the live system's behaviour. Within that basis, the message interface is exactly as documented and the observed payment and duplicate-join handling behaves correctly. The material risk is control: one key sets the prices and decides where the master routes users and their payments, and that key used the routing control twice in March 2026, after the original audit.

- **Interface confirmed in the bytecode.** All seven message headers listed in the original report occur exactly once in the deployed master code, and six of them appear in delivered messages.
- **Owner confirmed.** The master's owner getter returns the documented wallet. It is a `wallet_v5r1` controlled by one key, with one subscription extension installed.
- **No stop switch.** The original report inferred a stop mechanism from Tact exit code 133. The master exposes no `stopped` getter, and 133 is present in every Tact contract, so that inference has been removed.
- **Three "confirmed secure" statements withdrawn.** The original rated pricing, idempotency and gas handling as verified and secure on the strength of ABI excerpts. This edition reports what live traffic actually shows and rates each item Informational.

7 / 7

MESSAGE HEADERS FOUND IN
DEPLOYED CODE

1

MEDIUM FINDING, OWNER CONTROL

478

USER JOINS, 14 TO 22 SEP 2026

0

ABORTED JOINS IN THE WINDOW

2

ROUTING CHANGES BY THE OWNER
AFTER THE AUDIT

0.0326 TON

MASTER CONTRACT BALANCE TODAY

02 Scope, method and re-verification

AREA	WHAT WE DID
Code under review	The master contract at <code>EQAvJuElN0LP8c2YMZ4sKGwQRt_kmxmC494v8Y4TTHg0askJ</code> . Code cell 3,103 bytes, code hash <code>c845917da4a4ce1cb22aa00f65a82c3775e4c6a3c74453f9352e96d8d14fbfea</code> . Downstream contracts were identified from live traces and grouped by code hash. The original review used the client-supplied ABI and component names (<code>FtMaster</code> , <code>FtBaseProgramMain</code> , <code>FtBaseProgramUser</code> , <code>FtUserMain</code> , <code>FtUserStorage</code> , <code>FtSquad</code>); these names are not recorded on-chain.
Interface	Searched the deployed code bit by bit for every message header in the original report, and queried the master's get-methods (<code>owner</code> , <code>joinPrice</code> , <code>squadPrice</code> , <code>stopped</code>).
Administrative history	Listed every <code>Deploy</code> , <code>SetupJoinPrice</code> , <code>SetupSquadPrice</code> , <code>UpdateProgramAddress</code> , <code>GiftJoin</code> and <code>CreateSquad</code> message ever delivered to the master, with sender and date.

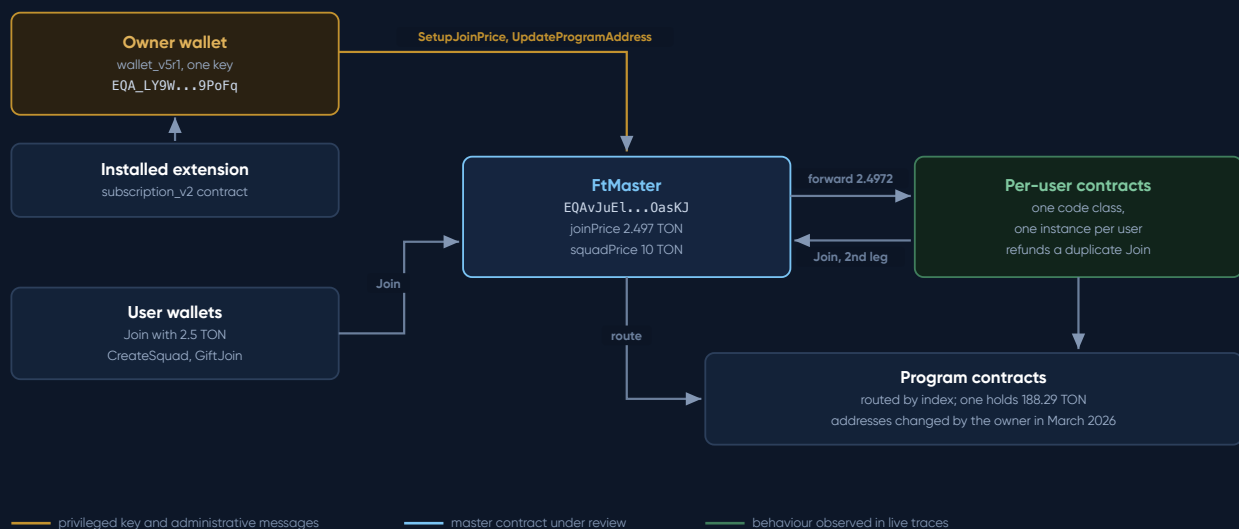
Behaviour in production	Analysed the last 1,000 master transactions (14 to 22 September 2026): message values, forwarded values, exit codes, the full trace of one join (19 transactions) and the traces of a wallet that joined twice.
Owner key	Read the owner wallet's interfaces, public key, seqno (1,684) and installed extensions.

Limits of this review

Without the source, access control can be observed but not proven: we can show who has sent each administrative message, not that no one else could. Behaviour that live traffic does not exercise, such as an underpaid user join, cannot be confirmed. The original report did not record a code hash, so we cannot prove that today's master code is the build reviewed in September 2025; this edition records the hash for future comparison.

03 System map and control

How a join moves through the system, and who controls it



Values are those observed on 22 September 2026. A user wallet sends 2.5 TON with Join; the master forwards 2.4972 TON to the user's contract, which calls the master again (second leg) before the flow fans out to program contracts. A duplicate join is refunded by the per-user contract.

ACTOR	POWER ON-CHAIN
Owner wallet EQA_LY9Wju...Q9PoFq	Returned by the master's owner getter. Sent the Deploy, both SetupJoinPrice messages (28 April and 2 May 2025) and both UpdateProgramAddress messages (1 and 12 March 2026). No other account has ever sent these messages. Holds 64.61 TON.
Owner extension 0:c7ccd0d8...4b03f8	A subscription_v2 contract installed in the owner wallet. Wallet v5 extensions can ask the wallet to send messages without a signature; this one is a recurring-payment contract.
Users	Send Join, GiftJoin and CreateSquad with the fee attached.
Program contracts	Receive routed joins. The largest, 0:988d747a...3269a8, holds 188.29 TON.

04 Findings

ID	FINDING	SEVERITY	STATUS
F-01	One key sets prices and program routing (added in this edition)	■ MEDIUM	■ OPEN
SKN-202	Initialisation ordering after deployment	■ INFORMATIONAL	■ RESOLVED
SKN-125	Pricing and value handling for Join and CreateSquad	■ INFORMATIONAL	■ OPEN
SKN-088	Duplicate Join and GiftJoin handling	■ INFORMATIONAL	■ OBSERVED
SKN-105	Gas reserve and storage of the master	■ INFORMATIONAL	■ OPEN
F-02	Source code not published (added in this edition)	■ INFORMATIONAL	■ OPEN

F-01 One key sets prices and program routing

■ MEDIUM

Location. Master contract, SetupJoinPrice (0x389f33c3), SetupSquadPrice (0x94f6ed64) and UpdateProgramAddress (0x062a2f22) handlers.

The owner wallet decides the price of every join and squad and, through UpdateProgramAddress, which contracts receive routed joins and the value attached to them. The original report listed governance as "centralized owner" and described the misrouting scenario, but did not rate it. The history shows the control is used: the owner changed program addresses on 1 and 12 March 2026, after the audit. The owner is a single-key wallet, so one compromised key could redirect new joins and their payments to an address of the attacker's choice. We make no statement about the purpose of the March changes.

Recommendation. Move the owner role to a multi-signature wallet, publish the program addresses and announce routing and price changes in advance, ideally behind a time delay.

Status. Open.

SKN-202 Initialisation ordering after deployment

■ INFORMATIONAL

The master is configured in several steps after deployment, so calls that arrive before configuration could meet incomplete state. On-chain, the Deploy arrived on 24 April 2025 11:54 UTC (87f52b2600...2e872b09), a configuration message from the program contract followed 9 seconds later, and the first Join 32 seconds after deployment. Configuration therefore completed before the first user call.

Status. Resolved for this deployment. For future deployments, reject user messages until configuration is complete.

SKN-125 Pricing and value handling

■ INFORMATIONAL

The master reads `joinPrice` = 2.497 TON and `squadPrice` = 10 TON today. In the window, all 478 user joins carried 2.5 TON, the master forwarded 2.4972 TON downstream and none aborted. A further 476 Join messages carrying 2.4867 TON, below `joinPrice`, are the second leg sent by Forton's own per-user contracts, not user payments. No underpaid user join occurred, so the rejection path was not exercised.

The original report marked this item "VERIFIED, implementation confirmed secure" with Medium impact, on the basis of the ABI field types. That conclusion is not supported without the source or a test against the underpayment path, and is withdrawn.

Recommendation. Publish the source, or a test report showing that joins below `joinPrice` are rejected and refunded, and that price changes cannot strand joins already in flight.

Status. Open. Consistent with observed traffic; underpayment handling not demonstrated.

SKN-088 Duplicate Join and GiftJoin handling

■ INFORMATIONAL

Asynchronous delivery on TON means a user can send Join twice. In the window two wallets did. We traced one of them: the first join ran through 15 transactions (`7b35a1c9cf...7f2227db`); the second (`2348828665...b88ec431`) produced a 4-transaction trace in which the per-user contract returned 2.4967 TON to the sender. The duplicate was refunded, not charged. No duplicate GiftJoin was available to observe.

The original "VERIFIED, implementation confirmed secure" wording is replaced by this observation.

Status. Observed working for Join in the case traced.

SKN-105 Gas reserve and storage of the master

■ INFORMATIONAL

TON contracts pay rent for their storage and fail if their balance cannot cover it. The master holds 0.0326 TON against 288 cells and 137,778 bits of storage. Storage due was 0 on the re-verification date and no join aborted in the window, so the design keeps the master funded from the traffic it handles. The margin is thin, and a quiet period or larger state would draw it down.

Recommendation. Keep a larger reserve on the master, or reserve a minimum balance in each handler, and monitor it.

Status. Open. No failure observed.

F-02 Source code not published

■ INFORMATIONAL

Neither the original review nor this edition had Forton's source code. Users and integrators cannot check which checks the contracts perform, and reviewers can only observe behaviour that traffic exercises.

Publishing verified source for the master and the downstream contracts would let the statements in SKN-125, SKN-088 and F-01 be proven rather than observed.

Status. Open.

05 Corrections to the October 2025 edition

Every statement in the original report was checked again on 22 September 2026. The following items were changed; the full claim-by-claim record is kept with this report.

ORIGINAL STATEMENT	WHAT WE FOUND	CHANGE
Security rating 98/100 "EXCELLENT", "Risk Level: NONE"	A bytecode-only review of a system controlled by one key cannot support a risk level of none. Numeric score removed; overall rating MEDIUM, driven by F-01.	■ CORRECTED
SKN-125, SKN-088, SKN-105: "VERIFIED, implementation confirmed secure", impact Medium	Supported only by ABI excerpts. Replaced by the live observations in section 04 and rated Informational.	■ CORRECTED
"All 3 security aspects have been verified"	Replaced by the specific observations above.	■ CORRECTED
Governance "centralized owner", not rated	Confirmed, and used after the audit. Rated as finding F-01.	■ CORRECTED
Owner "wallet_v5r1 (single-sig)"	One key, as stated. The wallet also has a subscription extension installed today.	■ CORRECTED
Error 133 "implying a stop/switch mechanism"; lifecycle with stop(), resume() and a Stopped state	No stopped getter exists; 133 is reserved in every Tact contract. Removed.	■ DROPPED
Fuzzing matrix and gas and reserve profiling tables	Tables of expected outcomes with no harness, run or results kept with the report. Removed.	■ DROPPED
Simulation playbooks S1 to S5 and the attack-surface map	Diagrams of intended behaviour, not executed tests. Replaced by the live-traffic map in section 03.	■ DROPPED
Office address "128 City Road, London EC1V 2NX"	SOKEN LTD's registered office is 86-90 Paul Street, London EC2A 4NE.	■ CORRECTED

Unchanged and re-confirmed: the master and owner addresses, the network, the Tact toolchain, the multi-contract design, all seven message headers, the September 2025 audit date, production status, and SKN-202.

06 Verification evidence

Live state, read on 22 September 2026

ITEM	VALUE
Master	EQAvJuE1n01P8c2YMZ4sKGwQRt_kmxmC494v8Y4TTHg0asKJ0:2f26e1259f494ff1cd98319e2c286c1046dfe49b1982e3de2ff18e134c780e6a
Status and balance	active, 0.0326 TON, 288 cells / 137,778 bits
Code hash	c845917da4a4ce1cb22aa00f65a82c3775e4c6a3c74453f9352e96d8d14fbfea
Deployment	24 April 2025 11:54 UTC, 87f52b2600...2e872b09, from the owner wallet
Last transaction	22 September 2026 11:20 UTC, 0f4e49f191...b59ae7d2
owner()	EQA_LY9WjuDSFsjtNGqBb5M8QQzmaMf9P8-MTPkFCHQ9PoFq
joinPrice / squadPrice	2.497 TON / 10 TON

stopped()	not present (exit code 11)
Owner wallet	wallet_v5r1, seqno 1,684, one extension: 0:c7ccd0d8582e9bc8cbcded3ea2d5915edc01d0621f7c7d83c21d6bbc914b03f8

Message headers in the deployed code

MESSAGE	HEADER	HEX	IN CODE	SEEN ON-CHAIN
Deploy	2,490,013,878	0x946a98b6	found once	yes
SetupJoinPrice	949,957,571	0x389f33c3	found once	yes, 2 messages
SetupSquadPrice	2,499,210,596	0x94f6ed64	found once	never sent
UpdateProgramAddress	103,427,874	0x062a2f22	found once	yes, 2 messages
Gift.Join	1,076,716,750	0x402d64ce	found once	yes, 7 messages
Join	3,607,685,656	0xd708ea18	found once	yes, continuous
CreateSquad	2,695,541,218	0xa0aab1e2	found once	yes, 50+ messages

Production traffic, 14 to 22 September 2026

MEASURE	RESULT
Master transactions in the window	1,000 (API page limit)
User joins (2.5 TON each)	478, from 476 distinct senders; forwarded 2.4972 TON each
Second-leg joins from per-user contracts	476, 2.4867 TON each
Aborted or failed joins	0 (compute exit code 0 in every case)
Wallets that joined twice	2; the traced duplicate was refunded 2.4967 TON

07 Conclusion

The Forton master contract is live, busy and behaves as its documented interface describes: every message header is where the ABI says it is, joins are forwarded and completed, and a duplicate join is refunded. Those are observations of a working system, and this edition presents them as such.

The overall rating is MEDIUM. The reason is control, not a defect we could demonstrate: one key sets the prices and the routing of every new join, it has used the routing control since the audit, and without published source the checks behind these flows cannot be confirmed. Moving the owner role to a multi-signature wallet with delayed changes, and publishing verified source, would address both.

08 Appendix: method notes

State and get-methods were read from the public tonapi.io and toncenter.com v3 APIs. Header search: the master code cell was decoded from its bag-of-cells and searched at every bit offset for each 32-bit header. Traffic analysis used the last 1,000 master transactions; each join was classified by its sender's code hash. Raw responses, the code and data cells and the analysis outputs are kept with this report.

09 Disclaimer

This report was prepared by SOKEN LTD (Companies House 15253906). The audit was performed in September 2025 and first published on 1 October 2025; this edition re-verifies its statements as of 22 September 2026. It covers the deployed code and on-chain behaviour at the addresses stated. The source code was not available. It is a point-in-time technical review, not a guarantee that the code is free of defects, and it is not financial, investment or legal advice. On-chain values change, so re-read any figure at the linked address or transaction before relying on it. Off-chain services, the application, key management and third-party integrations are outside the scope of this review.